Lab 35 — Compliance Audit with OpenSCAP

You will scan an Ubuntu host against a published security profile (CIS / DISA STIG), generate the HTML compliance report, and remediate one failed control.

Run on https://killercoda.com/playgrounds/scenario/ubuntu

Required software (free, apt): - `openscap-scanner`, `ssg-base`, `ssg-debian`, `ssg-debderived`

Step 1 — Install

The `oscap` binary moved packages: on Ubuntu 22.04 it ships in `libopenscap8`, while on Ubuntu 24.04 it ships in `openscap-scanner`. Install the SSG content first, then whichever scanner package this release provides.

```
apt update && apt install -y ssg-base ssg-debian ssg-debderived python3
```

```
apt install -y openscap-scanner || apt install -y libopenscap8
```

```
ls /usr/share/xml/scap/ssg/content/
```

You should see XCCDF files like `ssg-ubuntu*-ds.xml`. These are the official content streams from the SCAP Security Guide project.

Step 2 — Inspect available profiles

```
DS=$(ls /usr/share/xml/scap/ssg/content/ssg-ubuntu*-ds.xml | head -1)
oscap info $DS | grep -A1 Profile | head -20
```

Profiles include `cis_level1_server`, `cis_level2_server`, `pci-dss`, `standard`.

Step 3 — Run the audit

```
oscap xccdf eval --profile \
xccdf_org.ssgproject.content_profile_cis_level1_server \
   --results-arf arf.xml \
   --report report.html \
   $DS 2>&1 | tail -10
```

The HTML report is publication-ready; the ARF is the machine-readable evidence.

Step 4 — Read the headline numbers

```
grep -E "result|Score" report.html 2>/dev/null | head
```

```
oscap xccdf generate guide --profile
xccdf_org.ssgproject.content_profile_cis_level1_server $DS >
guide.html
```

Open `report.html` in a browser to see pass/fail per control.

Step 5 — Auto-generate a remediation script (Bash or Ansible)

```
oscap xccdf generate fix \
```

```
   --profile xccdf_org.ssgproject.content_profile_cis_level1_server \
```

```
   --output remediate.sh $DS
```

```
head -20 remediate.sh
```

```
chmod +x remediate.sh
```

Review **before** executing — auto-remediation can break running services.

Step 6 — Apply one specific fix

Pick a single failed rule from the report (e.g., `package_telnet_removed`):

```
apt purge -y telnet 2>/dev/null
```

```
oscap xccdf eval --rule
xccdf_org.ssgproject.content_rule_package_telnet_removed $DS
```

Re-run the full scan to confirm the score climbs.

Step 7 — Map to the framework you owe

Standard	Where this evidence goes
ISO 27001 A.12.6	Technical vulnerability mgmt
PCI-DSS 2.2	Configuration standards
NIST 800-53 CM-6	Configuration settings
MAS TRM	Baseline security configurations

Attach the ARF + HTML report to the audit evidence folder.

Free online tools

- **SCAP Security Guide** — https://github.com/ComplianceAsCode/content

- **Open Vulnerability Assessment Language** — https://oval.cisecurity.org
- **CIS-CAT Lite** (free benchmark assessor) — https://www.cisecurity.org/cybersecurity-tools/cis-cat-lite
- **InSpec by Chef** — https://www.inspec.io
- **NIST National Checklist Program** — https://ncp.nist.gov

What you learned

- SCAP is the open standard for compliance-as-code.
- A single XCCDF profile produces audit, remediation script, and human report.
- How to map technical evidence to the framework the auditor actually asks for.